

FlowSync – Authentication Policy

1. Overview

This document defines the authentication and account security policy for FlowSync, a B2B SaaS productivity platform. It is used by support agents and AI systems to diagnose, resolve, and escalate authentication-related issues such as login failures, MFA errors, account lockouts, and session problems.

2. Authentication System Overview

FlowSync uses a secure authentication system based on:

- Email + password login
- Multi-Factor Authentication (MFA)
- OAuth-based third-party login (where enabled)
- Session-based token authentication

All authentication events are logged for security and audit purposes.

3. Login Policy

3.1 Standard Login Flow

1. User enters email and password
2. System validates credentials
3. MFA is triggered (if enabled)
4. Session token is generated upon success
5. User is redirected to dashboard

3.2 Common Login Failures

- Invalid credentials
- Expired session tokens
- Account lock due to failed attempts
- Server-side authentication service downtime

3.3 Login Rate Limiting

- Maximum 5 failed login attempts allowed
 - Account is temporarily locked for 15 minutes after threshold is reached
-

4. Password Policy

4.1 Password Requirements

- Minimum 8 characters
- At least one uppercase letter
- At least one number
- At least one special character

4.2 Password Reset Flow

1. User requests password reset
2. System sends secure reset link via email
3. Link expires after 15 minutes
4. User sets new password

4.3 Password Reset Issues

- Email not received
 - Expired reset link
 - Invalid token usage
-

5. Multi-Factor Authentication (MFA)

5.1 Supported MFA Methods

- Authenticator apps (TOTP)
- Email OTP
- SMS OTP (region-dependent)

5.2 MFA Failure Scenarios

- Incorrect OTP entry
- Time drift in authenticator app
- Lost MFA device
- OTP delivery delays

5.3 MFA Recovery Process

- Identity verification required
 - Backup codes can be used if available
 - Support escalation required for MFA reset
-

6. Account Lock Policy

6.1 Lock Conditions

- 5 consecutive failed login attempts
- Suspicious login activity detected
- Security policy violation

6.2 Unlock Process

- Automatic unlock after 15 minutes (standard cases)
 - Manual unlock via support for security cases
 - Identity verification required for sensitive unlocks
-

7. Session Management

7.1 Session Rules

- Sessions expire after 24 hours of inactivity
- Active sessions are refreshed automatically
- Users can be logged out from all devices manually

7.2 Session Issues

- Frequent logouts due to token expiry
 - Cross-device session conflicts
 - Corrupted session state
-

8. OAuth Authentication (Third-Party Login)

8.1 Supported Providers

- Google
- Microsoft (Azure AD)
- Slack (enterprise integration login)

8.2 OAuth Issues

- Redirect URI mismatch
- Access denied by user
- Expired authorization token
- Workspace/account mismatch

8.3 OAuth Recovery Steps

- Re-initiate login flow
 - Re-authorize permissions
 - Clear cached session and retry
-

9. Security Monitoring

FlowSync continuously monitors authentication behavior for:

- Brute force attempts
- Suspicious IP activity
- Geo-location anomalies
- Device fingerprint mismatches

Suspicious activity may trigger:

- Temporary account lock
 - MFA re-verification
 - Security alert notification
-

10. Escalation Conditions

Authentication issues are escalated when:

- Account cannot be recovered via automated flow
 - MFA reset is required without backup codes
 - Suspicious activity indicates potential breach
 - Enterprise account authentication failure occurs
-

11. AI System Usage (Agentic Integration)

This policy is used by AI agents to:

- Diagnose login and authentication issues
 - Suggest password reset and MFA recovery steps
 - Detect account lock scenarios
 - Decide escalation vs self-resolution
 - Generate structured support tickets
-

End of Document
